

Fuzzy Testing

Prof. Dr. Raphael Herding

Fuzzy Testing Introduction

- **Regression testing:** ensures that the system is working as expected even after a change has been done.
- **Fuzzy-Testing:** ensures that the system is still working when is used aberrant (abnormal).
- Blackbox- and Whitebox-Fuzzing is possible.
- General Approach
 - Automatically generate test cases
 - Execute many aberrant tests against the running system
 - Monitor the behavior of the system under test

Fuzzy Testing Process



Simple Example

- Normal HTTP GET Request

GET /index.html HTTP/1.1

- Aberrant Requests

AAAAAA...AAAA /index.html HTTP/1.1

GET //////////index.html HTTP/1.1

GET %n%n%n%n%n%n.html HTTP/1.1

GET /AAAAAAAAAAAAAA.html HTTP/1.1

GET /index.html HTTTTTTTTTTTTTTTP/1.1

GET /index.html HTTP/1.1.1.1.1.1.1.1

Lab

- **ft-01**: Run a coverage-guided fuzzer against untested code, let it discover crashes automatically, and learn to read crash artifacts

Mutation-based Fuzzing

- Smart and stupid approaches exists.
- Using valid inputs as base and modifying them.
- **Random-based:** randomly modifying the input (stupid)
- **Replay-based:** using previously tracked and working inputs and fractionally modifying them (smarter)

Lab

- **ft-02:** Measure test quality beyond coverage: use mutation testing to find inputs your tests would never detect a change in

Generation-based Fuzzing

- Smart approach
- Is not using existing inputs
- Inputs are generated based on a predefined specification (RFC, docs, OpenAPI Spec, etc.).
- Certain aberrant have to be specified within the documentation
- Advantages
 - Comprehensive due to knowledge about the specification
 - Complex cases possible since automation is using complex specifications (e.g. OpenAPI Spec)
 - APIs at least have specifications in place
- Disadvantages
 - Specs have to be very detailed
 - Thinking out-of-the-box (How can the system used aberrant is required)

Evolutionary-based Fuzzing

- More advanced approach
- Feedback of existing cases will be used for generating further cases
- Learning of protocols and interfaces is possible
- Can be used in White-Box-Fuzzing since the statement coverage can be evaluated in order to generate more suitable test cases.
- Uses genetic algorithms or ML-based approaches.

Lab

- **ft-03:** Speed up fuzzing by replacing raw bytes with structured inputs, so the fuzzer spends its budget on logic rather than format